

Active Reconnaissance:

→ we use browser & some tools ping, traceroute, telnet & nc to gather information network, system & service

★ In browser, we have this tools, FoxyProxy, Wapptigen, User-Agent Switcher & Manager.

★ Ping: header 8 bytes.
man ping

★ traceroute: In linux & macOS ⇒ traceroute <IP>
Windows ⇒ tracert <IP>

TTL

★ netcat: nc -lvp Port_No.
nc <IP-addr> Port_No.

Passive.

- we use whois to query WHOIS server
- nslookup to query DNS servers
- dig to query DNS servers
- Online tools: DNSDumpster & Shodan.io
- Passive and Active Reconnaissance.

★ whois: Port → 43 → for incoming Requests.

we can learn from whois

- Registrar: Via which registrar was the domain name registered.
- Contact info: Name, organization, address, phone
- Creation, updation, & expiration dates
- Name server: Which server has to resolve the domain name?

★ nslookup: IP address - of domain.

• nslookup^{option} <domain>

• dig <domain> Type.

} Domain Information Group.

★ DNSDumpster (website): To find subdomain

Nmap:

- i) which systems are up?
- ii) What services are running on these systems?

★ ARP scan

★ ICMP scan

★ TCP/UDP ping scan

→ Network segment: group of computer connected using shared medium, Physical connection.

→ Subnetwork: one or more network segment connected together, logical connection.

→ Two type of subnets:

- i) /16 $\Rightarrow$ 65000 hosts
- ii) /24 $\Rightarrow$ 250 hosts

• nmap -iL list-of-hosts.txt

• nmap -sL TARGETS

Masscan

• masscan <IP>/24 -p 443

• masscan <IP>/24 -p 80,443

• masscan <IP>/24 -p 22-25

• masscan <IP>/24 --top-ports 100

Host Discovery:

• nmap -sn Target

→ To discover hosts on same network subnet as the target we use ARP scan

• nmap -PR -sn TARGETS

• nmap arp-scan -L: This command will send ARP queries to find all valid IP addresses on your local network.

→ Host Discovery using ICMP

• nmap -PE -sn <Target>

• nmap -PP -sn <Target> (ICMP Time Stamp Request)

→ TCP & UDP scan:

• nmap -PS -sn <IP add>

-PS 21-25

• nmap -PA -sn <Target>

• nmap -PU -sn <IP>

- ★ -sS ⇒ Syn scan
- -sU ⇒ UDP scan
- -O ⇒ OS Detection
- -sV ⇒ Detect version of service
- -v ⇒ Increase verbosity (-vv preferred).
- -OA ⇒ Save result in & Major format.
- -ON ⇒ Normal format save
- -OG ⇒ Save result in grepable format
- -A ⇒ If we don't care about how loud we are.
- -T <1-5> ⇒ Timing template (Increase speed of scan)
Higher speed are noisier
- -P 80 ⇒ Specific port
- -P 1000-1500 ⇒ Range
- -p- ⇒ all ports
- --script ⇒ script library.
- --script=vuln ⇒ Activate all of the script in "vuln" category.

Three basic scan type:

- TCP Connect Scans (-ST)
- SYN "Half-open" scans (-SS)
- UDP scans (-sU)

→ Several less common port scan types

- TCP Null scans (-sN)
- TCP FIN scans (-sF)
- TCP Xmas Scans (-sX)

★ -sn : Ping Sweep Scan. (Send ICMP Request).

script :

- safe : won't affect target
- intrusive : Not safe ; likely to affect the target
- vuln : Scan for vulnerabilities
- exploit : Attempt to exploit a vulnerability
- auth : Attempt to bypass authentication for services
- brute : Attempt to brute force credential for running services
- discovery : Attempt to query running services for further information about network
- --script = <script-name> to run specific script
- Directory where all scripts are available = /usr/share/nmap/scripts

★ NULL, FIN, XMAS scans for bypassing firewalls.

for • -Pn : Treat target as being alive.

• -f : fragments

• -mtu <number> :

↓
Multiple
of 8

• --scan-delay <time> ms : add delay b/w packet sent.

• --badsum : Invalid checksum

OWASP - TOP 10:

→ Categories that related to failure in architecture & system design

Security Misconfiguration (A02):

System, server, or Application are deployed with unsafe default, incomplete settings or exposed services.



This are not bug but mistakes in environment set up.

• Common Patterns

- i) Default credential & weak pattern
- ii) Unnecessary service or endpoints exposed to internet
- iii) Misconfigured cloud storage or permissions.
- iv) Unrestricted API access or missing authentication / authorization
- v) Error msg
- vi) Outdated software framework or container.
- vii) Exposed AI/ML endpoints without proper access control.

Software Supply chain Failures:

- when an Application relies on component, libraries or module that are compromised & outdated.
- No error in code but tools & library depend upon it.

→ Common Pattern:

- i) Using unverified & unmaintained libraries & dependency.
- ii) Automatic install or update without verification.
- iii) Over-reliance on 3rd Party Model.
- iv) Insecure build pipeline.
- v) Lack of Monitoring for vulnerabilities in dependencies after deployment.

Cryptography failures:

- When encryption is used incorrectly or not at all.
- It includes weak algorithm, hardcoded key and poor key management.

→ Common Pattern:

- i) Using deprecated algorithm: MD5, SHA-1, or ECB mode
- ii) Hard coded secret in code
- iii) Poor key rotation or Management
- iv) Lack of encryption for sensitive data.
- v) Self aligned or invalid TLS certificate.
- vi) Using AI/ML system without proper secret Handling.